Who Takes the Bait: Understanding phishing susceptibility with practitioner intelligence

Or: How I Learned to Stop Worrying and Love the Phish

M is for Mansoor

- Tester of pens (SE and appsec mostly)
- Professional bridge burner
- Former press photographer
- Love to phish
- Don't love fish

Why?

The Big Phish

36%

of breaches in 2025 utilized phishing

The Research Problem

- Phishing is the #1 initial access vector for data breaches (Verizon DBIR, 2025)
- 1 out of 3 of data breaches in 2025 utilized phishing
- Effective phishing targets specific individuals with personalization
- Attackers profile targets methodically using open-source intelligence (OSINT)
- Defenders have no equivalents beyond web scanners and some monitoring tools

The Research Problem

- Current training simulations test one scenario at one point in time
- The crucial gap: Attacker knowledge is in the minds of offsec professionals and threat actors
- No systematic, pre-attack method to assess which roles or departments face the greatest exposure
- Lack of insight leads to reactive measures to different types of phishing (mass phishing, spear phishing, whaling, etc.)

Exhibit A: TURKEYS…IN MARCH?!?

IMPORTANT: RECALL ON TURKEY AND HAM THIS HOLIDAY SEASON

Hello,

You are receiving this notification because you recently shopped at a store that is currently recalling ALL turkey, ham, salami, and chicken products due to contamination.

Please call (646) [redacted] right away to speak with a food safety representative to determine if your purchase was impacted by this contamination.

You can provide the representative with your store number 9[redacted] so that they can view your purchase.

This is an important matter and we want to make sure everyone stays safe this holiday season. Please call right away.

Thank you,
Food Safety Team

The Questions I Wanted Answers To

- RQ1: What factors are most influential in phishing, and how do these factors relate to organizational roles and industry contexts?

- RQ2: What parallels exist between the persuasion mechanisms used in phishing and those employed in digital marketing?

- RQ3: Can the above be systematically encoded into a model that produces actionable and explainable susceptibility assessments?

Some Nuances

- Susceptibility: relative likelihood of engagement with a phishing attempt
  - Portable across organizations due to industry and departmental norms
- Risk: susceptibility × impact
  - Requires knowing asset values and access levels, which vary per company
- Strongly believe that phishing susceptibility is the necessary first input to phishing risk calculation

Methodology

The Survey

- Mixed-methods survey
- 20 closed-ended questions
  - Quantitative weights for the model
- 3 open-ended questions
  - Qualitative thematic insights

The Survey

- Question categories:
  - Demographics & experience (Q1–Q3)
  - Department susceptibility: most vs. least (Q4–Q5)
  - Targeting factors, protective factors (Q6–Q7)
  - Industry context, timing, pretext design (Q8–Q12)
  - OSINT sources & tools (Q13–Q14)
  - Personalization, persona crafting (Q15–Q16)
  - Psychological levers, emotional tone, credibility (Q17–Q19)
  - Success metrics (Q20)
  - Open-ended: invisible factors, gut-feel, suggestions (Q21–Q23)

Quantitative Analysis Methods

- Three analysis approaches for different question types
- Frequency analysis for multi-select questions
  - Usage examples: Q7, Q11, Q13, Q20
- Borda Count for rank-order questions
  - Usage examples: Q6, Q16, Q17, Q19
- Net Susceptibility Scoring for paired 'most/least' questions
  - Usage examples: Q4, Q5

Nerdy Math: Net Susceptibility Scoring

- Questions 4 and 5 ask which departments are most or least susceptible, with the same 8 options

$$score_{net} = \left(\frac{count_{most}}{n}\right) - \left(\frac{count_{least}}{n}\right)$$

- Produces scores between -1 and +1
  - The closer the score is to +1, the more susceptible the department was scored to be

Nerdy Math: Final Susceptibility Score

- Composite 'raw' susceptibility score

$$score_{raw} = department_{susceptibility} + industry_{modifier} + modifier_{total}$$

- Final susceptibility score

$$score_{susceptibility} = \frac{score_{raw} + 1}{2} \times 100$$

Math in Simpler Terms

- Formula transforms raw scores (−1 to +1) onto a 0–100 scale where 50 is neutral
- 0 = maximally resistant, 100 = maximally susceptible
- Susceptibility thresholds:
  - Critical (≥75)
  - High (≥55)
  - Medium (≥35)
  - Low (<35)

Findings

Who We Asked (n = 27)

- Experience:
  - 59.3% (n = 16): 10+ years
  - 18.5% (n = 5): 7–9 years
  - 22.2% (n = 6): 4–6 years
  - 0%: 2–3 years
- All 27 have at least four years of professional experience, with most having over 10 or more years

Who We Asked (n = 27)

- Primary roles (multi-select):
  - Red teamer: 51.9%
  - Social engineer: 48.1%
  - Penetration tester: 44.4%
  - Threat emulation: 40.7%
  - Threat hunter: 22.2%
  - Other: 40.7%

Who We Asked (n = 27)

- Specified "Other" roles:
  - Cyber threat intelligence
  - Red team leadership
  - Blue team and disaster recovery
  - Incident response
  - Application and product security
  - Offensive security tool development
  - Security research
  - Security management

Department Susceptibility

Poll: Which department do you think scored the MOST susceptible?

IT helpdesk

Human resources

Marketing/PR

Legal

Entry-level employees

Executive assistants

Finance

Department Susceptibility

Department	Net Susceptibility Score
Marketing/PR	+0.7407
Human resources	+0.5926
Entry-level employees	+0.4444
Finance	+0.3333
Executive assistants	+0.1481
Legal	-0.1111
IT helpdesk	-0.2222

Table 1

Department Susceptibility

- MOST susceptible: Marketing/PR (+0.74)
  - Their job is to send emails to and open emails from strangers…
- LEAST susceptible: IT Helpdesk (-0.22)
  - Technical exposure helps them be better equipped (mostly)

Psychological Levers by Effectiveness

Poll: Which psychological lever do you think is the STRONGEST?

Reciprocity

Authority

Peer influence/herd behavior

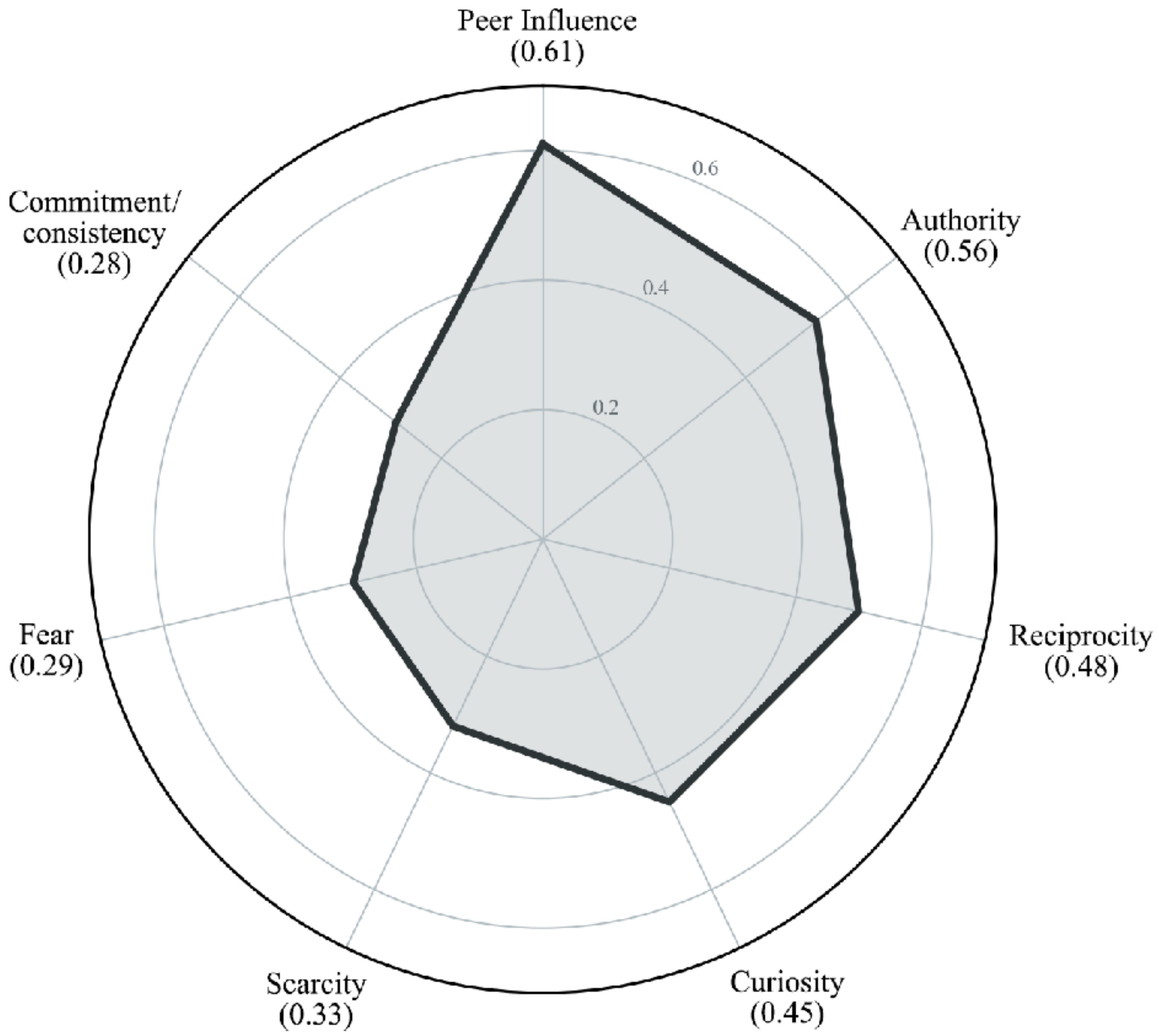
Curiosity

Fear

Scarcity

Commitment/consistency

Psychological Levers by Effectiveness



Psychological Levers Examined

- Peer influence (or 'herd behavior') ranked #1, ahead of authority
  - Marketers call this social proof
  - Operates through identification ('people like me are doing this')
  - It works because…it also has authority built into it!
  - Diverges from roughly two decades of phishing literature that emphasizes authority is most effective
- Fear is the pretty much the LEAST effective (per these folks)
  - "PLS SIR UR ACCUNT WILL BE SUSPNDED!!" has gotten old…

Targeting Factors

Targeting Factor	Normalized
Visibility/exposure of information	0.6296
Personality traits (e.g., over-sharer)	0.4815
Access level	0.4074
Responsiveness or email behavior	0.3827
Other	0.1235
Past breach involvement	0.0370

Table 2

Credibility

Credibility Factor	Normalized
Has a plausible call to action	0.4568
Matches the recipient's job duties	0.3457
Comes from a familiar sender type (e.g., HR, IT)	0.3333
Includes known tools/services (e.g., DocuSign, Zoom)	0.2716
Mimics internal tone or style	0.2222
Avoids obvious red flags (spelling, bad formatting)	0.2099
Uses real names or departments	0.1358

Table 3

Targeting Factors & Credibility

- What the email asks matters more than who sent it
  - The implication: teach employees to evaluate the request, not just the sender
- For better training:
  - Instead of "Is this really Darlene from HR?"
  - Ask "Is this how my company usually does shit?"

Protective Factors

- What makes employees LESS likely to engage with phishing?
    1. Technical role expertise: 59.3%
    2. Organizational culture of verification: 51.9%
    3. Multi-layer communication style: 44.4%
    4. Security awareness training signals: 40.7%
- DBIR: training improved reporting rates 4x but only reduced click rates by 5% in relative terms

Pretexts In Action

Pretext: Targeting Marketing/PR

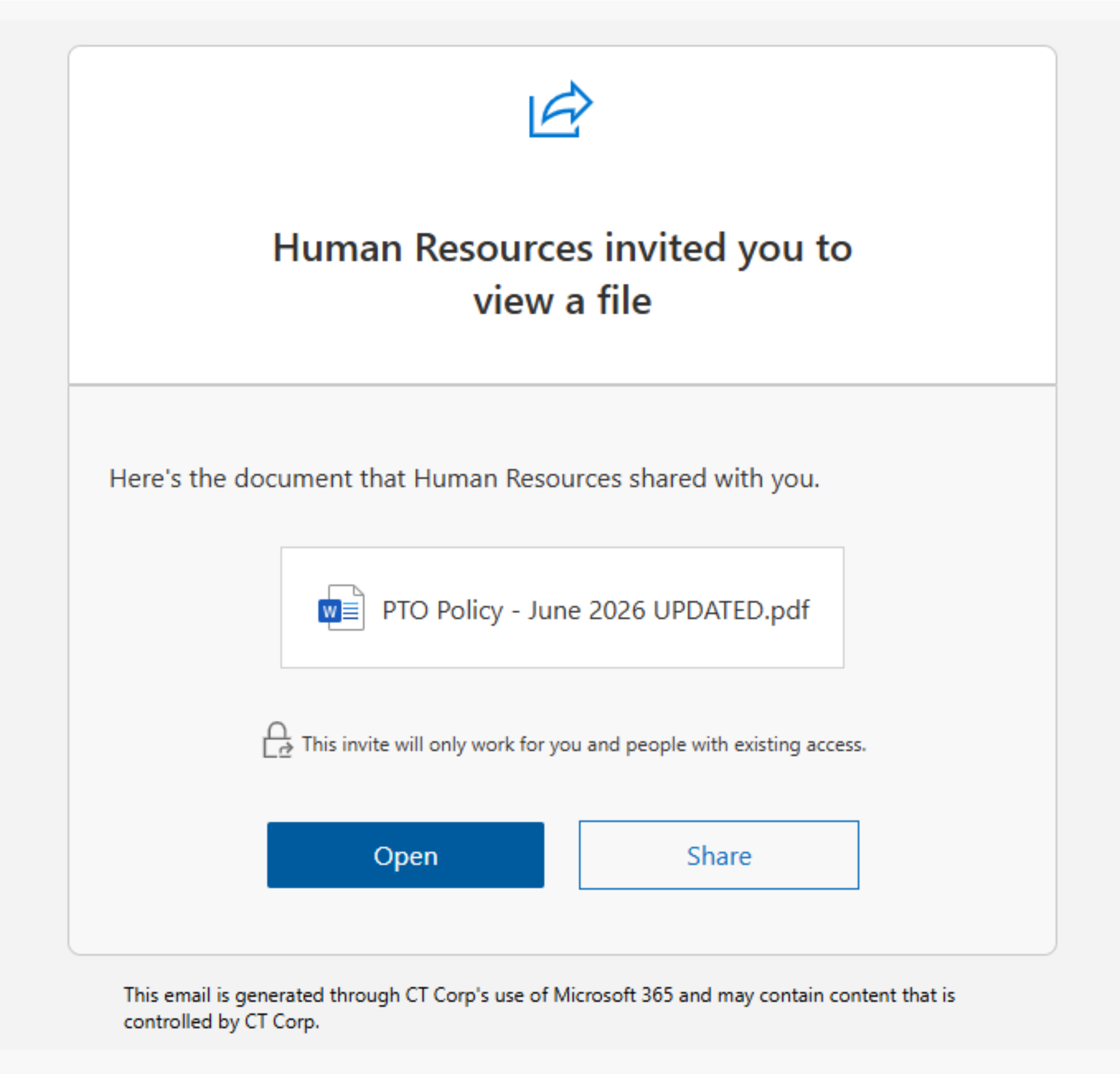
Mansoor Ahmad shared "Ella Langley - Lucas Oil Stadium (May 9) Photos" with you

Mansoor Ahmad (mansoor.ahmad@hackboi.com) invited you to edit the folder "**Ella Langley - Lucas Oil Stadium (May 9) Photos**" on Dropbox.

"Hey Julia, here are the photos from the Lucas Oil Stadium show on May 9. It was absolutely ROCKING, Ella is so so good!! Let me know which ones you like, thanks!"

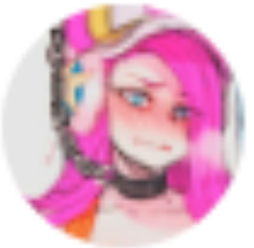
Add to Dropbox

Pretext: Credibility and Curiosity



Pretext: Credibility and Curiosity…NOT?

Mark Hear shared a document



Mark Hear (mark@domain.com) has invited you to **view** the following document:

PDF PTO-policy_updated_June2026.pdf

Open

Does this item look suspicious? Block sender

Google LLC, 1600 Amphitheatre Parkway, Mountain View, CA 94043, USA
You have received this email because mark@domain.com shared a document with you from Google Docs.

Google™

Pretext: Entry-level Using Credibility

Dear Nick Mullen,

You are now enrolled in Quarterly Phishing and Cybersafety Training. Please complete this training no later than May 19, 2026.

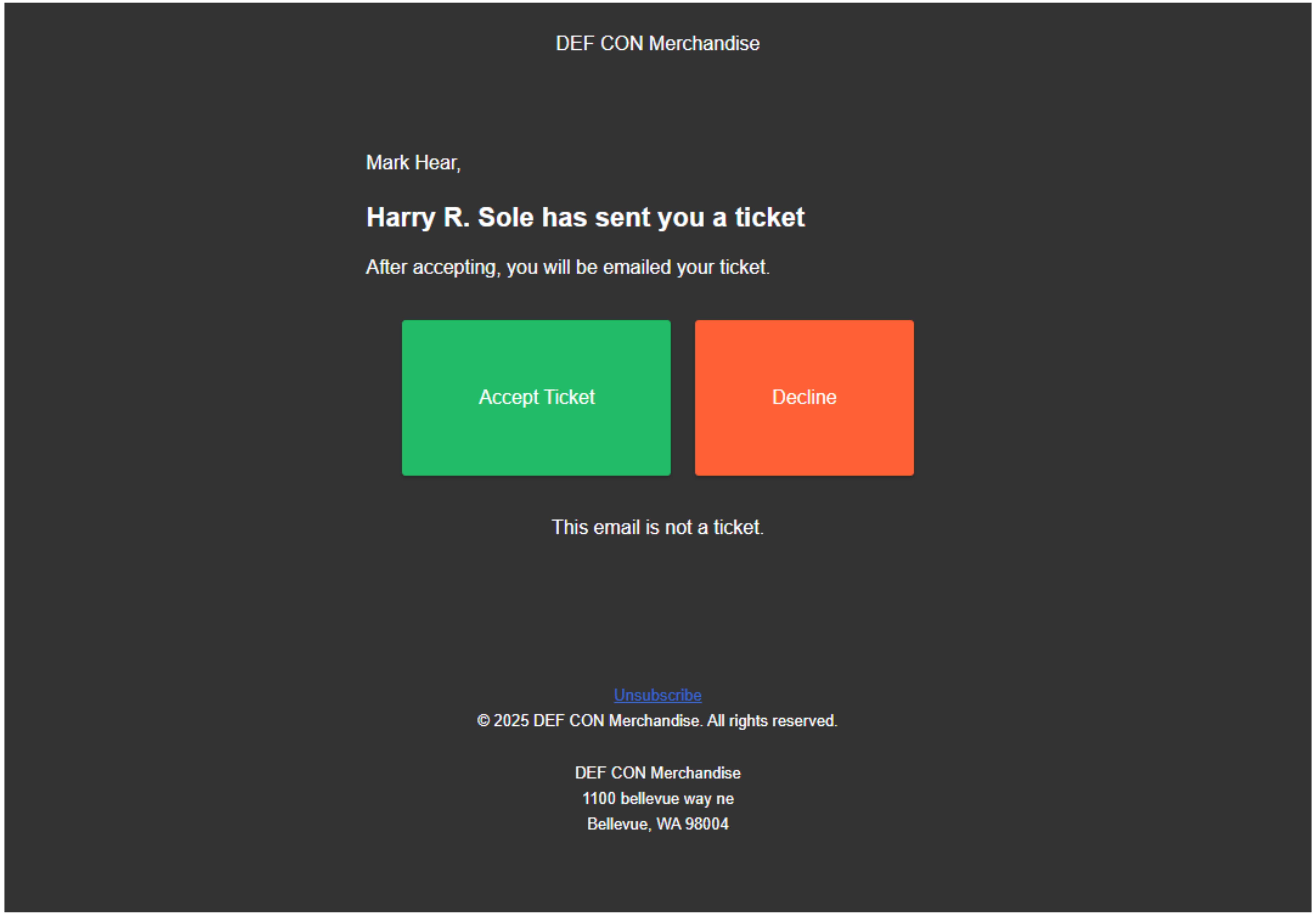
The assignments you've been enrolled in are displayed below:

- Phishing and Cybersafety
- 2025 Kevin Mitnick Security Awareness Training
- Remote Work: Cyber and Physical Security
- AI At Work: Use It Wisely

Please use this link to sign in and start your training:

https://training.knowbe4.com/auth/saml/48rb71ylu0g

Pretext: DEF CON Tickets from Harry R. Sole


DEF CON Merchandise

Mark Hear,

Harry R. Sole has sent you a ticket

After accepting, you will be emailed your ticket.

Accept Ticket

Decline

This email is not a ticket.

Unsubscribe

DEF CON Merchandise
1100 bellevue way ne
Bellevue, WA 98004

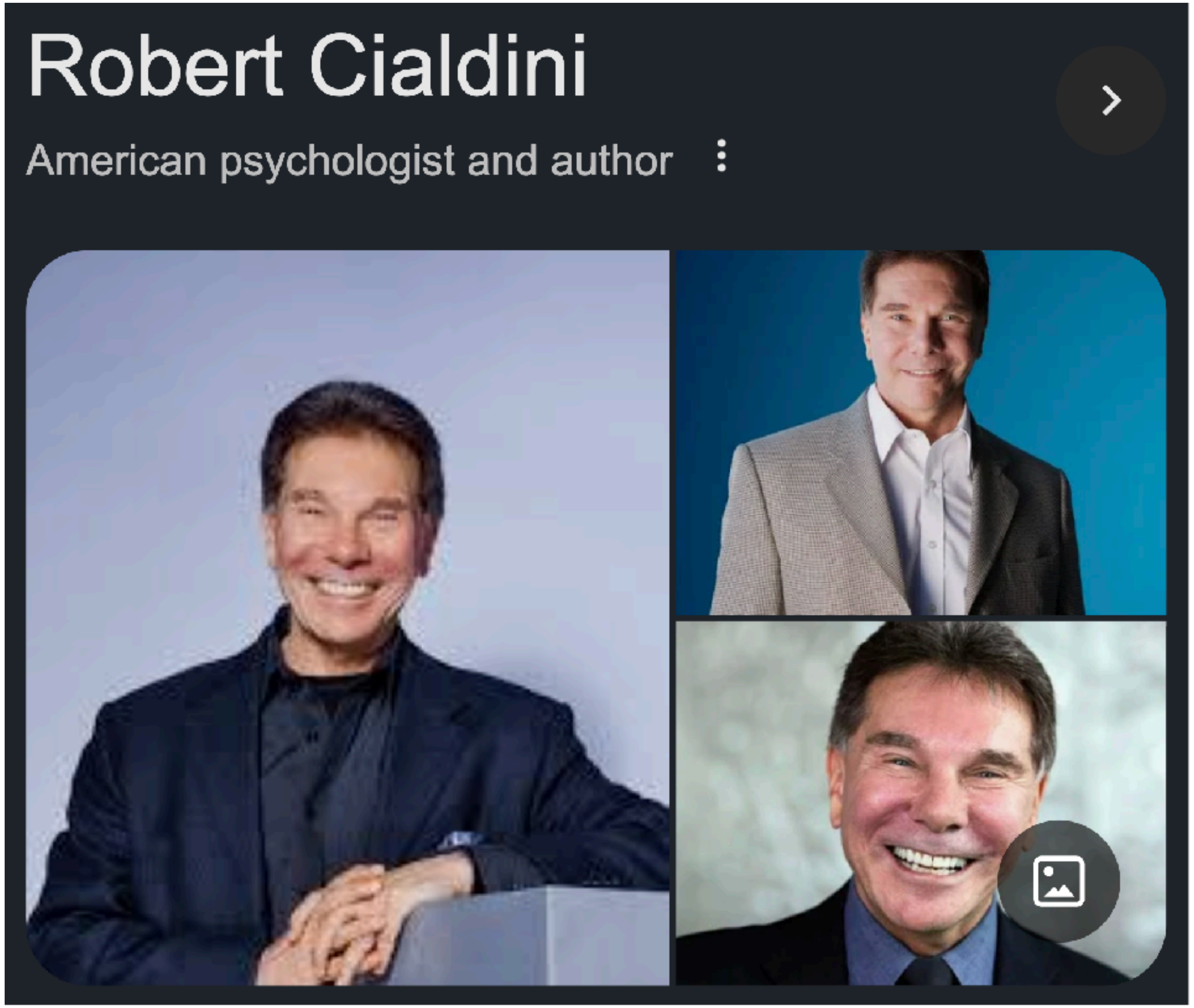
Qualitative Analysis

Can literally spend all day talking about those, so we won't...

Read the full thesis if you're really interested though ;)

The Marketing Parallel

The Marketing Parallel (RQ2)



The Marketing Parallel (RQ2)

Origin: Coined by psychologist Robert Cialdini in his 1984 book *Influence*, it is widely considered one of the core principles of persuasion.

The Marketing Parallel (RQ2)

- The six dimensions where phishing and marketing converge:
  1. Psychology:
     - Peer influence being the #1 lever is equivalent to social proof in marketing
  2. Segmentation:
     - Specific department or role targeting can be understood as audience segmentation
  3. Personalization:
     - 96.3% experts vouching for customized pretexts is comparable to personalized marketing

The Marketing Parallel (RQ2)

- The six dimensions where phishing and marketing converge:

4. Emotional triggers:
    - Experts unanimously (100%) agreeing that tone matters is similar to emotional advertising
5. Timing:
    - Majority of the experts (92.6%) say timing matters, which is send-time optimization in marketing
6. Credibility:
    - Plausible action being more important than the sender ID is akin to marketing's 'message over source' cues

Enter PhishScore

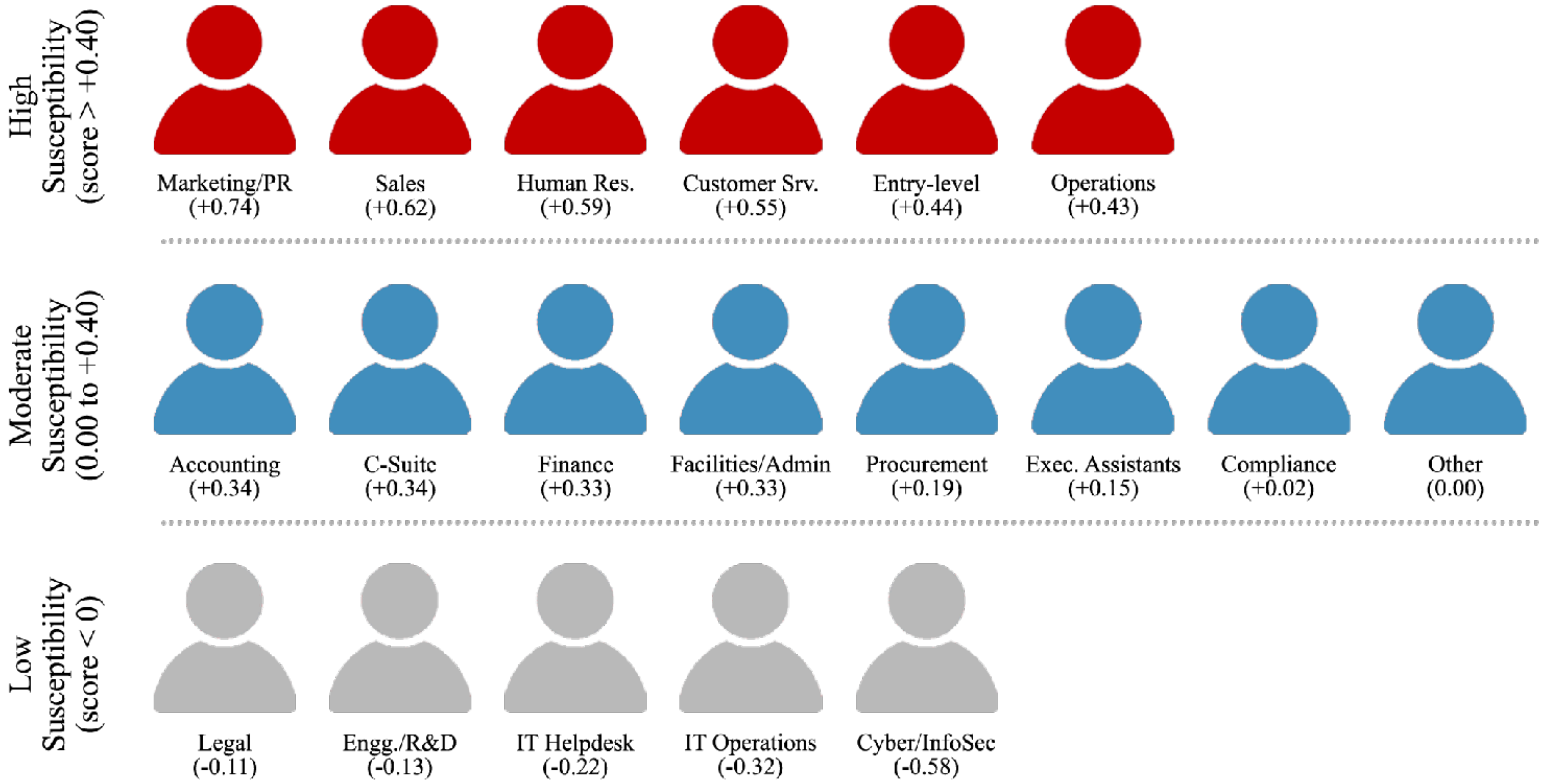
PhishScore

- A scoring engine that turns 27 practitioners' expertise into a 0-100 score for any role
  - Pure model: 8 surveyed departments
  - Enhanced model: 19 departments, 18 industries, modifiers
- CLI and report generation:
  - Interactive and scriptable options
  - Reports output in text, JSON and HTML formats
- Three interactive modes:
  - Default, Offensive, Defensive

Enhanced Model: 19 Department Scores

- 8 departments from direct survey data
- 11 departments inferred via weighted blending of surveyed departments
  - High tier → external-facing, high-volume communication roles
  - Low tier → all technical departments and "Legal"
- Observation: C-Suite lands moderate, not high
  - Authority does not work on those who hold it

Susceptibility Across 19 Departments



PhishScore Features

- Inputs:
  - Target name, department and company
  - Industry (18 options)
  - Context modifiers (new hire, remote, deadline, etc.)
- Outputs:
  - Susceptibility score (0–100)
  - Category (Critical/High/Med/Low)
  - Ranked recommendations across 7 dimensions
  - Defensive insights and reasoning
  - Saved reports (optional)

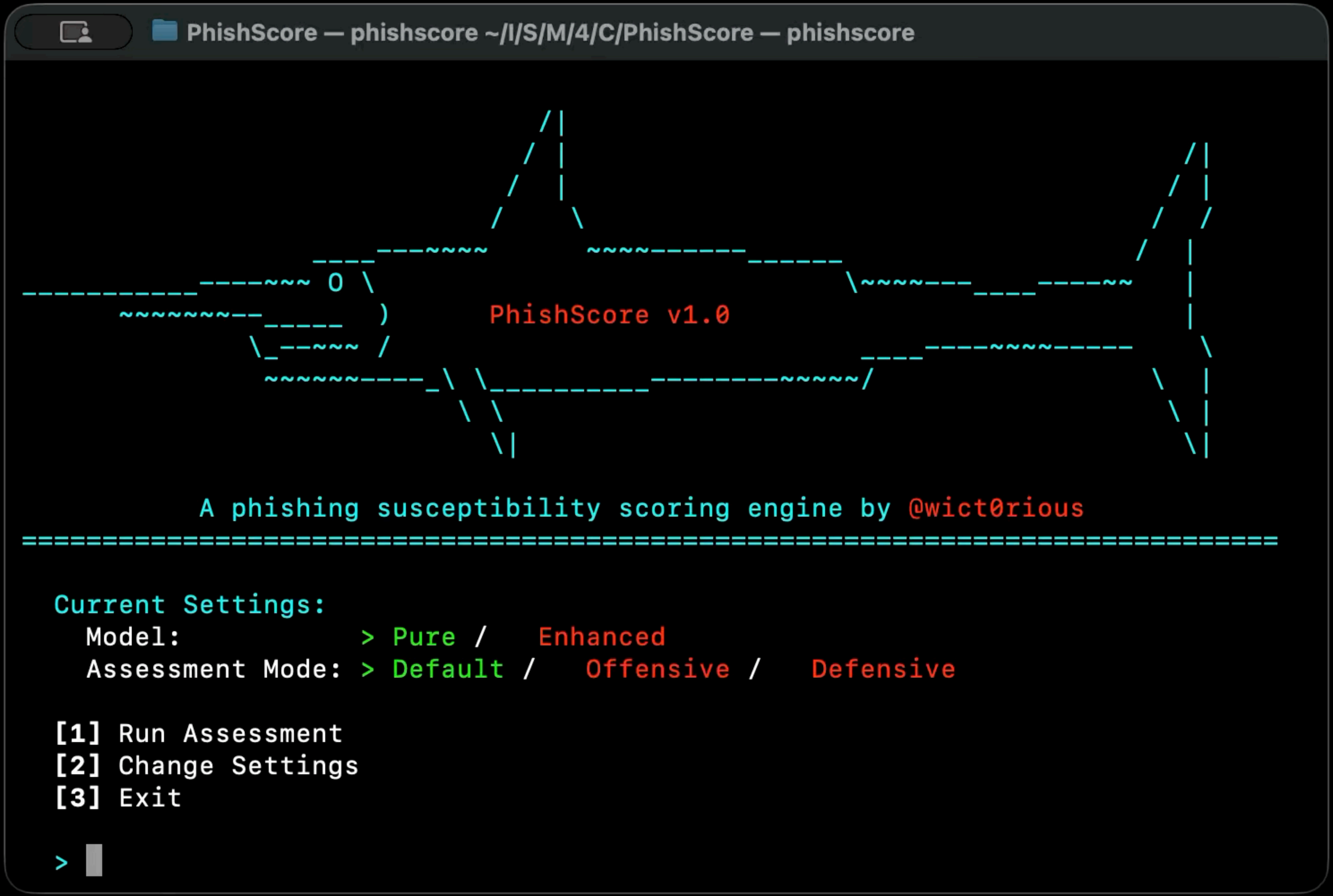
Non-traditional, ML-based Implementation

- Traditional ML learns from labeled outcomes (e.g., "clicked"/"did not click")
- No click data, so learns from the expert consensus instead
- Survey responses → Borda count aggregation, frequency analysis, net scoring → weight tables
- Scoring is deterministic arithmetic, not a trained statistical model
- Resulting model is a 'scoring engine', not a classifier

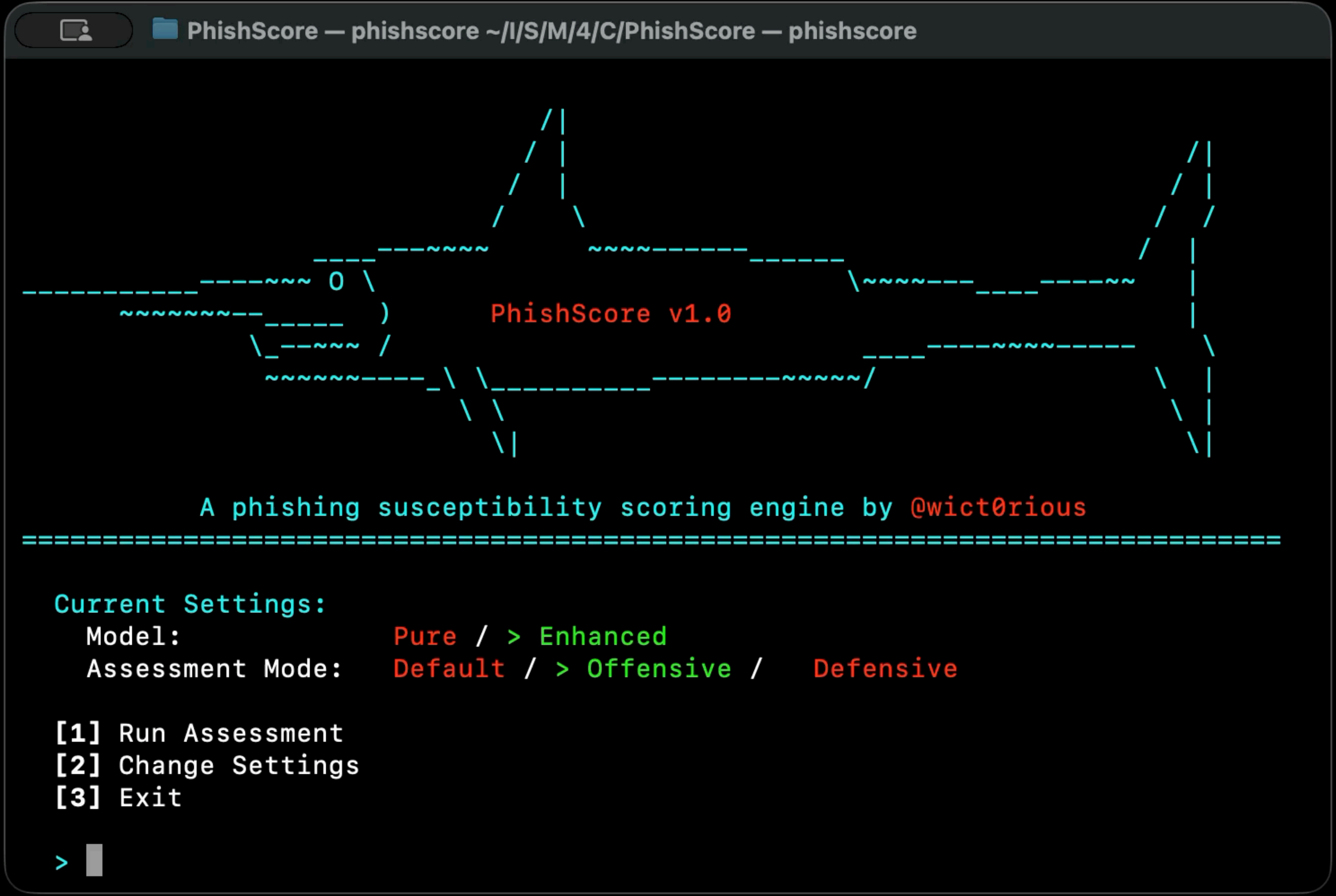
PhishScore Demo

(featuring at least one of you guessing and yelling scores)

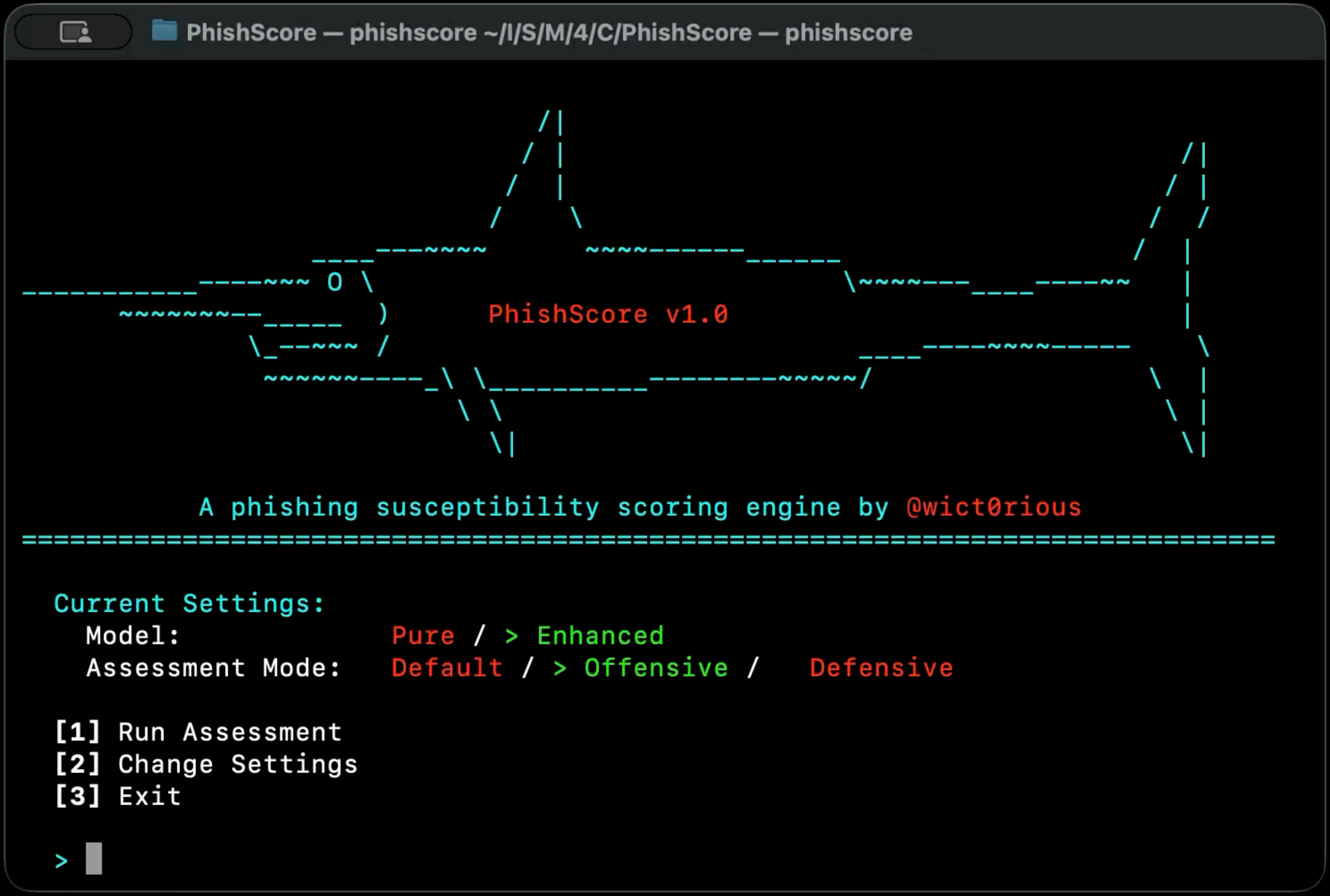
Cybersecurity Guy at a Tech Company



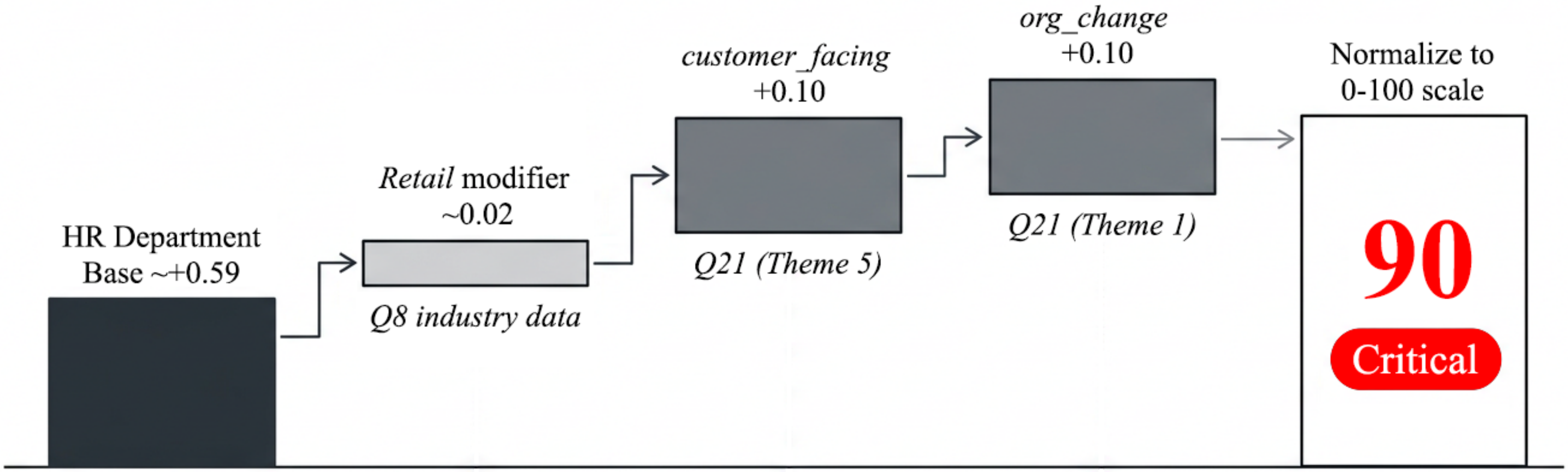
HR Lady at an M&E Company



Paralegal at a Loan Company



Anatomy of a Critical Score



Limitations

- Sample size:
  - 27 practitioners not sufficient for subgroup analysis
- No validation:
  - Study does not reflect resulting real-world click rates
- No technical controls factored:
  - Model assesses the human factor only, no technical defenses

The Human Variable

The Significance of Luck

- Human susceptibility is not a fixed quantity
  - Shifts with cognitive state, emotional condition, workload, personal circumstances, factors that change hour to hour
- Practitioners attributed phishing outcomes partly to luck
  - "The same email to the same [recipient] at a different time/ date may go unnoticed"
  - Phishing is "a numbers game and just a matter of time"
- DBIR: median click rate floors and persists at ~1.5%

Profile, Not Person

- Susceptibility score applies to an employee <u>role</u>
  - Score factors department, industry and situational modifiers
- Does <u>not</u> assess a specific individual's character or competence
  - Two identical employees' profiles may respond very differently
  - Personality, experience and situational awareness create variation that can not be encoded

Profile, Not Person

- Scores should <u>inform</u> role-level training priorities, policy and process decisions, and resource allocation for security teams
- Scores should <u>never</u> be used for judgments about individual employees or punishment

Wrapping Up

The Three Big Takeaways

1. Phishing keeps winning

2. Digital marketing and advertising is scummy

3. Take this shit seriously, please

Acknowledgments

Willie Zhang

sno0ose

Levi Leksey

JAE

Chris Kirsch

Alethe Dennis

SteveD3

ZERO

Apun

Joseph Carson (Wiretrap)

Dustin Heywood (EvilMog)

Valerye Hedlund (CausticKirby-Z)

Jakub Udymowski-Grecki (Kuba Gretzky)

AJ Hammond (ajm4n)

_sn0ww

s0ups

Benjamin Toombs

Joey Marinello

TechByTom

Winter

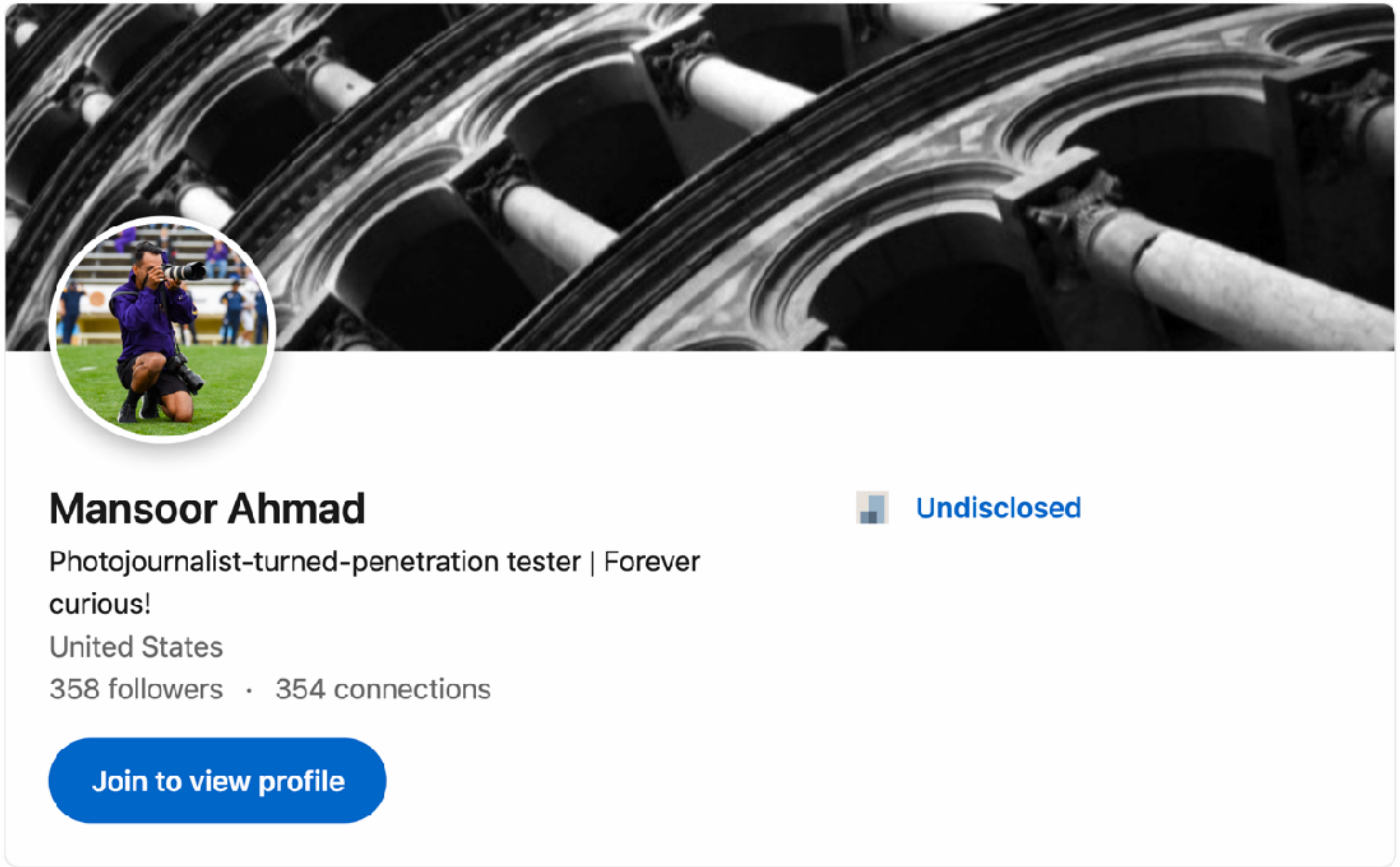
Patrick Laverty

Carlos Rivera

And 5 others...

Increase Shareholder Value With Me Here

linkedin.com/in/mansoor-ahmad-khan/



Full Thesis and PhishScore

Full Thesis:
link.mnsu.edu/phish

PhishScore:
github.com/wict0rious/PhishScore

Thank You!